

Recent **cyberattacks attributed to Iranian threat actors** extend beyond typical network disruption. Rather than an isolated incident of sabotage, this type of attack sits within a broader context defined by Iran's reliance on asymmetric retaliation and historical proxy doctrine. Iran-aligned threat actors increasingly leverage cyberspace as a strategic equalizer.

For the Islamic Revolutionary Guard Corps (IRGC) and the Ministry of Intelligence and Security (MOIS), cyber operations provide a low-cost, high-impact mechanism for retaliation without crossing any geographical boundaries. In this environment, global organizations face increased cyber risk, as traditional malware deployment intersects with novel identity abuse. The shift from custom-built wiper malware to native administrative abuse removes a critical detection guardrail that historically protected enterprise networks.

From Custom Binaries to Identity Abuse

Iranian cyber actors' current tactical shift is driven less by a lack of malware development capabilities than by the strategic advantages of living-off-the-land (LotL) techniques. Operations designed to cause disruption have undergone a change since 2023: Instead of relying heavily on bespoke tools, the methods now employed are part of a larger trend toward greater scale and improved evasion.

During the recent wiper incidents, threat actors operating under the Void Manticore (Handala) persona did not deploy a novel wiper or traditional compiled malware. Instead, the attackers compromised highly privileged identities, pushing legitimate remote-wipe commands to over 200,000 devices globally.

This shift from custom binaries to administrative abuse helps explain the current dynamic. In this context, Iranian advanced persistent threats (APTs) increasingly appear to view enterprise administrative tools not solely as IT infrastructure, but as weaponizable assets within a wider disruptive framework. This distinction is critical for understanding how Iranian state-aligned actors perceive mobile device management (MDM) platforms not as management tools, but as high-leverage attack vectors that bypass traditional endpoint detection and response (EDR) telemetry.

Moving Up the Escalation Ladder

Already in **2012** and 2016, Iranian actors were launching significant disruptive operations throughout the region. Tracing the history of their cyber retaliation against perceived geopolitical slights, we see a clear, escalating pattern of capability and intent over the last decade among groups linked to the IRGC and MOIS.

The Blunt Instruments (2016–2019)

During this period, threat actor groups such as **Curious Serpens** (APT33, Elfin) and **Evasive Serpens** (APT34, OilRig) targeted IT infrastructure with high-visibility disk-wiping malware.

- **Shamoon resurgence:** Following its initial **debut** in 2012, **Shamoon 2** and **Shamoon 3** were deployed against Middle Eastern entities. These attacks utilized spearphishing to gain initial access, eventually relying on the Eldos RawDisk driver to bypass Windows APIs and overwrite the master boot record (MBR).
- **ZeroCleare and Dustman:** Deployed heavily against the energy and industrial sectors, wipers like **ZeroCleare** and its successor **Dustman** mirrored Shamoon's reliance on modified legitimate drivers to achieve destructive effects.

In this era, Iranian actors prioritized visible retaliation over stealth. Their cyberattacks projected power and inflicted maximum operational immobilization.

Ransomware Smokescreen: Plausible Deniability and Supply Chain Compromise (2020–2022)

As scrutiny intensified, Iranian threat actors adapted their operational playbook to introduce plausible deniability. The strategic focus shifted from overt, state-sponsored sabotage to mirroring financially motivated cybercrime. This tactical pivot was primarily spearheaded by the threat actor group **Agonizing Serpens** (Agrius).

- **The Agonizing Serpens wiper suite (Apostle and Fantasy):** Rather than relying on traditional spear phishing, Agonizing Serpens frequently exploited publicly available one-day vulnerabilities in public-facing web applications to drop custom **web shells**. Once initial access was established, the group **deployed** payloads designed to blur the lines between espionage and extortion.
- **Evolution of Apostle:** Initially observed as a pure wiper disguised as a ransomware operation, **early versions of Apostle** lacked the actual capability to decrypt files, indicating that data destruction was the primary intent. Later variants, however, were patched to function as legitimate ransomware, complicating attribution and delaying incident response efforts by forcing defenders to treat the event as a standard cybercrime incident.
- **Supply chain exploitation:** The deployment of the **Fantasy wiper** represented a significant escalation in Agrius's targeting methodology. By compromising a trusted third-party Israeli software developer, the threat actors executed a supply-chain attack that impacted downstream victims across multiple global verticals.

Masquerading as a ransomware syndicate offered a critical strategic advantage to Iranian cyber actors by obfuscating state alignment while still achieving the desired effect of business disruption and economic damage.

Hacktivism as a Front: Psychological Operations and Cross-Platform Destruction (2023–2025)

Between 2023 and 2025, the threat landscape shifted once again. The traditional APT model gave way to a surge of state-directed hacktivist personas. Groups such as Void Manticore and the Handala Hack Team operated openly on platforms like **Telegram**, leveraging destructive attacks as a component of broader psychological operations and information warfare.

- **BiBi, Hatef, and Hamsa wipers:** The emergence of these malware families highlighted a critical technical evolution: cross-platform capability. While earlier wipers were

strictly Windows-focused, threat actors deployed the .NET-based Hatef wiper for Windows environments alongside the **Bash-based Hamsa and BiBi wipers** targeting Linux servers.

- **File-level destruction:** Technically, these **variants** moved away from the complex MBR-wiping techniques of the Shamoon era. Instead, they opted for rapid, recursive file-level destruction, overwriting targeted files with 4096-byte blocks of random data.
- **MultiLayer and BFG Agonizer:** Concurrently, collaborative deployments between Agonizing Serpens and Boggy Serpens (aka **MuddyWater**) introduced **highly modular wipers like MultiLayer and BFG Agonizer**. These operations frequently abused legitimate remote monitoring and management (RMM) tools to distribute the payloads at scale.

During this period, wipers became just one component of a hybrid threat model. Destructive deployments were consistently paired with aggressive data exfiltration, creating simultaneous hack-and-leak operations.

The Era of Identity Weaponization (2026 and Beyond)

The most recent **escalation** in Iranian offensive cyber operations marks a fundamental departure from the previous decade of tradecraft. While the strategic motivations remain consistent, the technical execution has shifted from deploying compiled, custom malware to a highly destructive form of LotL. Instead of attempting to evade EDR agents with sophisticated wiper binaries, these groups are targeting the enterprise management plane itself.

- **Exploitation of mobile device management (MDM):** The primary attack vector relies on the compromise of highly privileged identities with access to cloud-based management consoles, such as MDM/RMM platforms.
- **Built-in command abuse:** Once administrative access is secured, threat actors abuse legitimate, built-in features — specifically, the built-in remote wipe or factory reset commands. By broadcasting these commands across the entire managed tenant,

attackers can simultaneously wipe hundreds of thousands of corporate laptops, servers, and mobile devices (including bring-your-own-device (BYOD) hardware) across global environments.

- **The EDR hidden zone:** Because no traditional wiper malware is dropped, and no anomalous disk-writing processes are initiated by an unknown executable, EDR and antivirus platforms can remain largely blind to the activity. The destructive commands are authenticated, authorized, and delivered directly from trusted vendor infrastructure.

This methodology offers unprecedented scale and speed. It eliminates the resource-intensive requirement to develop, test and update custom malware families while guaranteeing a catastrophic impact on the target's operational capabilities.

The Outlook: A Changed Strategic Calculus

For cybersecurity professionals and network defenders, the threat model has shifted significantly. The primary lesson from this evolutionary timeline is that an organization's infrastructure is only as strong as its weakest administrative credential. When threat actors can reliably turn the tools used to manage and secure a fleet into the very instruments of its destruction, the defensive paradigm must evolve from focusing purely on malware detection to enforcing strict identity resilience.

For state-aligned threat actors, disrupting operations through native identity abuse is a highly efficient, scalable way to project power and inflict economic damage. By understanding this tactical evolution, organizations can transition from a posture of reactive malware hunting to one of verified, identity-centric resilience.

To mitigate the risk of state-aligned administrative abuse, security teams must implement the following strategic countermeasures:

- **Treat the management plane as Tier-0:** **Cloud-based management platforms** must be classified as critical infrastructure. Changes to MDM policies, role assignments, and

enrollment scopes should be subjected to the same rigorous change-control processes as domain controller modifications.

- **Enforce strict conditional access and Zero Trust:** Access to administrative portals must be gated behind robust conditional access policies. Valid credentials and multi-factor authentication (MFA) are no longer sufficient; **access must also require verification** from a known, compliant, and cataloged corporate device. Stolen credentials attempting to authenticate from an unknown device or anomalous IP address range must trigger a hard block, not merely an MFA step-up prompt.
- **Eliminate standing privileges:** Organizations must audit and radically reduce the number of accounts holding standing global administrator roles. Implement **privileged identity management (PIM)** to ensure that administrative access is granted only on a Just-In-Time (JIT) basis, complete with approval workflows and strict timeboxing.
- **Isolate and air-gap backups:** In an environment where the cloud tenant itself is compromised, cloud-connected backups are highly susceptible to the same destruction. Maintaining offline, air-gapped, and immutable backups is a non-negotiable requirement for ensuring organizational survivability against native administrative wiping operations.

Additional Resources

- **Insights: Increased Risk of Wiper Attacks** – Unit 42, Palo Alto Networks
- **Boggy Serpens Threat Assessment** – Unit 42, Palo Alto Networks
- **Threat Brief: March 2026 Escalation of Cyber Risk Related to Iran** – Unit 42, Palo Alto Networks

Updated March 23, 2026, at 3:26 p.m. PT, to add an Additional Resources section with links